

Son Teknik İnceleme

İnceleme özeti

Bu belge, Gateway/security/platform merge'lerinden sonraki mevcut main mimarisini değerlendirir. Son tam solution CI doğrulamasında restore, Release build (--warnaserror) ve dotnet test başarılı olmuştur. Bu, derleme ve mevcut unit-test kapsamının yeşil olduğunu gösterir; gerçek altyapı concurrency testlerinin tamamlandığı anlamına gelmez.

Güçlü taraflar

- Finansal source of truth MSSQL'dir; Redis para doğruluğunun kaynağı değildir.
- Wallet transfer balance/idempotency/transaction/ledger state'ini tek SQL transaction içinde commit eder.
- Double-entry Debit = Credit hem Domain hem persisted SQL seviyesinde kontrol edilir.
- Durable idempotency duplicate money movement'i engeller.
- External HTTP finansal SQL transaction dışında çalışır.
- Fraud risk sinyalleri client'tan değil server state'ten türetilir.
- JWT + durable session yaklaşımı high-risk işlemlerde revoke kontrolü sağlar.
- YARP Gateway public auth, internal routing, rate limit, health ve load balancing sınırı oluşturur.
- Backend/provider business endpointleri downstream service credential ile direct-bypass'a karşı korunur.
- Swagger tüm Web API'lerde standarttır ve production'da varsayılan kapalıdır.
- Merkezi package management ve warnings-as-errors kullanılır.
- xUnit v3 + Moq altyapısı vardır ve CI test çalıştırır.

Önceki isteğin karşılanma durumu

- YARP Gateway: ****tamamlandı****.
- Servis trafiğinin Gateway üzerinden geçirilmesi: ****uygulandı****; FinWallet provider adapterları /providers/* kullanır.
- Gateway JWT enforcement: ****tamamlandı****.
- Load balancing / health / rate limit / request limits: ****tamamlandı****.
- Tüm API'lere Swagger: ****tamamlandı****.
- OWASP/API abuse hardening: ****uygulama seviyesinde tamamlandı****; volumetric DDoS için edge/ingress/WAF koruması deployment sorumluluğudur.
- MSSQL/Redis/HttpClient/YARP performance review: ****tamamlandı****.
- Parametrik operasyon/tuning değerlerinin appsettings'e taşınması: ****tamamlandı****.
- Unit test mock kontrolü: önce eksikti; ****xUnit + Moq eklendi****.
- Register'dan transfera happy-path dokümanı: ****tamamlandı****, fakat public funding eksikliği açıkça belirtilmiştir.
- AI mimari karar anlatımı: ****tamamlandı****.
- Tüm maintained proje dokümanlarının TR+EN olması: ****tamamlandı****.

Bilinçli olarak appsettings'e taşınmayan değerler

Kullanıcının “parametrik tüm elementler” talebi operasyonel/tuning değerleri için uygulanmıştır. Aşağıdaki değerler bilinçli olarak runtime switch değildir:

- JWT imza algoritması;
- PBKDF2 V1 scheme/work factor migration semantics;
- double-entry eşitliği;
- financial decimal invariants;
- durable idempotency semantics;
- transaction/locking correctness rules.

Bu değerlerin config ile serbestçe değiştirilmesi güvenlik veya mevcut verinin doğrulanabilirliğini bozabilir.

Açık teknik borçlar

- 1 Public BankDeposit ve BankWithdrawal.
- 2 Durable FraudEvents/manual review.
- 3 Outbox/Inbox ve güvenilir post-commit notification.
- 4 ReconciliationRuns/ReconciliationIssues.
- 5 Transaction-history/read model.
- 6 Centralized masked structured logging + OpenTelemetry/alerting.
- 7 Gerçek MSSQL/Redis/YARP integration ve concurrency test suite.
- 8 Logout/session-revoke public endpoint.
- 9 Dependency vulnerability/SBOM pipeline.
- 10 Production ingress/WAF/network-policy/TLS deployment hardening.

Öncelik önerisi

En mantıklı sıra:

- 1 BankDeposit;
- 2 BankWithdrawal + cutoff;
- 3 integration/concurrency tests;
- 4 Outbox/Inbox + notification;
- 5 FraudEvents/manual review;
- 6 transaction history;
- 7 reconciliation;
- 8 telemetry/operations hardening.

Son karar

Mevcut sistem side-project amacı için sağlam bir financial-core/gateway baseline'idir. “Production-ready banking platform” olarak değerlendirilmemelidir; funding/withdrawal, reconciliation, observability ve gerçek altyapı concurrency testleri tamamlanmadan bu iddia doğru olmaz.